55. Capstone: Secure Edge for a Small App

55. Capstone: Secure Edge for a Small App

Phase: Phase 13 — Capstones
Estimated time: 4–6 days
Slug: `55-capstone-edge`

Learning objectives

- Terminate TLS at edge
- Reverse proxy to app
- Firewall + SSH hardening + health checks
- Probe latency/error metrics

Prerequisites

Complete prior lessons. Prefer a Linux VM for `ip`/`ss`/`nft` examples; macOS works for many `curl`/`dig` drills. Type every command yourself and keep a lab notes file.

Why this matters

Ship a small app edge: TLS, reverse proxy, health checks, minimal firewall. Capstone for secure-enough production instincts.

Core concepts

What you must be able to explain:

- Terminate TLS at edge
- Reverse proxy to app
- Firewall + SSH hardening + health checks
- Probe latency/error metrics

Mental model for `55-capstone-edge` (exercise kind `cap_edge`):

- Prefer **measurable** checks (exit codes, ICMP replies, DNS rcode, HTTP status, socket state) over vibes.
- Separate **reachability** (can packets flow?) from **correctness** (right service, cert, route, identity).
- Ask: *which layer's tool falsifies my current hypothesis?* Then run that tool.
- Record the exact command that proved the root cause — that becomes your playbook snippet.

Worked commands

Run these on a lab host. Linux VM preferred for `ip`/`ss`/`tcpdump`/`nft`; macOS is fine for many `curl`/`dig`/`ping` drills. Your addresses and timings will differ — match the *shape* of the output and the conclusion you draw.

Example 1

```
ping -c 2 1.1.1.1; dig example.com +short; curl -sS -o /dev/null -w
'%{http_code}\n' https://example.com; ss -tln | head
```

Sample output:

```
icmp ok / A record / 200 / LISTEN lines
```

Interpretation: Playbook order: local stack → L3 → DNS → L4 listen/connect → L7. Capstones and interviews reward this sequence.

Example 2

```
ip route get 1.1.1.1; traceroute -n 1.1.1.1 2>/dev/null | head -4 || true
```

Sample output:

```
1.1.1.1 via 192.168.1.1 dev eth0 src 192.168.1.20
1 192.168.1.1
```

Interpretation: `ip route get` is the fastest 'which path would this host take?' check on Linux.

Example 3

```
curl -sS -o /dev/null -w 'namelookup=%{time_namelookup} connect=%{time_connect}
ttfb=%{time_starttransfer}\n' https://example.com
```

Sample output:

```
namelookup=0.020 connect=0.040 ttfb=0.120
```

Interpretation: Percentiles beat averages for latency SLOs; single curl samples teach which phase dominates.

Mini-lab

1. Re-type every worked command for **Capstone: Secure Edge for a Small App** and paste outputs into lab notes.
2. Introduce one controlled failure in the lab (wrong DNS, firewall drop, bad route) and recover using only this lesson's tools.
3. Write a 5-line playbook: symptom → first command → expected healthy output.
4. Complete the exercise stubs; then explain each function's return value without looking.

Failure modes

Symptom	Likely cause	Next check
App exposed directly on :80 public	See common mistakes	Re-run lesson commands
No health checks	See common mistakes	Re-run lesson commands
Certs without renewal plan	See common mistakes	Re-run lesson commands
Timeout with no RST	Silent drop / blackhole	tcpdump + compare path

Study tip for Capstone: Secure Edge for a Small App

Before each new command, write a one-line hypothesis. If the result falsifies it, update the hypothesis instead of stacking random tools. Note equivalents across OS (`ip` ↔ `ifconfig`/`route`, `ss` ↔ `netstat`). Re-run two commands from this lesson tomorrow from memory and explain the sample outputs out loud.

Evidence habit

When pages are down, prefer evidence (`ip route get`, resolver answer, packet capture, listener list) over intuition. Document **command → output → conclusion** in a lab notebook so the same path is reusable on-call. Change one variable at a time; write a one-line hypothesis before each new tool.

Common mistakes

- App exposed directly on :80 public
- No health checks
- Certs without renewal plan

Exercises

Work in `exercises/55-capstone-edge/`. Read that folder's `README.md` before coding.

```
cd exercises/55-capstone-edge
chmod +x test.sh exercise.sh 2>/dev/null || true
./test.sh
```

What you will build

Edit `exercise.sh` and implement `edge_should_terminate`, `forward_ip_from`, `health_checks_hit`. Each function is a tiny retrieval drill for **Capstone: Secure Edge for a Small App** — return the exact tokens/flags/labels from the lesson. Keep the comment above each function describing when you would use that fact on-call. Run `./test.sh` until all 3 assertions pass.

Study loop

- **A (Drill):** make tests pass
- **B (Apply):** run 2–3 real commands from this lesson in your lab and note outputs
- **C (Challenge):** rewrite answers from memory next day

Do not open `solutions/55-capstone-edge/` until after an honest attempt.

Self-check

Answer without scrolling up:

1. What is public?
2. How detect expiry?
3. How prove health?

Further reading

- https://nginx.org/en/docs/